

Privacy Policy Review — TZI CRM

Reviewed: `app/privacy-policy/page.tsx`

Compared against actual product: `SAAS_CRM_BACKEND` , `SAAS_CRM_FRONTEND`

Verdict: Not suitable as-is. The document is a generic website privacy-policy template. It says nothing about what this product actually does with data: WhatsApp/Instagram/Facebook messaging via Meta's Graph API, Gmail sync via Google OAuth, live GPS tracking of sales staff, or device-login session data. Two of these gaps are compliance-blocking, not just cosmetic.

⚠️ **This is not legal advice.** Have a lawyer (ideally one familiar with India's DPDP Act 2023 and Meta/Google platform policies) review the final text before publishing.

1. Controller vs. processor role (missing entirely)

TZI-CRM is a **data processor** for the leads/deals/contacts a tenant's sales team enters about *their own* customers, and a **data controller** for tenant admin/user account data. This distinction matters under India's DPDP Act 2023 and for any GDPR-adjacent customer. Add a section clarifying this, and note that tenant Admins are responsible for having a lawful basis to process their end-customers' data (leads) in the CRM.

2. Critical — Meta Platform data (WhatsApp/Instagram/Facebook) — missing, and likely a Meta App Review blocker

Evidence: `SAAS_CRM_BACKEND/controllers/meta.controller.js` , `whatsappCloud.controller.js` , webhook routes for WhatsApp/Instagram/Facebook, message/comment schemas storing DMs, comments, and media.

Meta requires apps using the Graph API / WhatsApp Cloud API to have a privacy policy that explicitly covers:

- What Meta/WhatsApp/Instagram/Facebook data is collected (messages, comments, contact info, page/business tokens, media attachments)
- How it's used, stored, and for how long
- A **Data Deletion Instructions URL or callback** (required for Meta app review — the current policy has neither)

Required addition — "Meta Platform Data":

"When you connect a WhatsApp Business, Instagram, or Facebook Page account, the Service accesses and stores messages, comments, contact details, and media exchanged through those channels, and business tokens necessary to maintain the connection, solely to provide messaging and CRM features within your account. This data is not shared with third parties beyond what's necessary to operate the integration. You may request deletion of this data by [contacting support@techzarinfo.com / via account settings]."

Also add a **Data Deletion Instructions** page/URL if one doesn't exist — required for Meta app review to remain active.

3. Critical — Gmail / Google OAuth data — missing, required by Google API Services User Data Policy

Evidence: `SAAS_CRM_BACKEND/utils/gmailService.js` (scope includes `gmail.readonly`), `models/GmailToken.js`.

Google requires apps requesting sensitive/restricted scopes (Gmail read access qualifies) to disclose, in the privacy policy:

- What Gmail data is accessed and why
- That the app's use of Gmail data adheres to Google's **Limited Use** requirements (no use for ads, no transfer to third parties except to provide/improve user-facing features, no human reading of content except for security/support with consent)

Required addition — "Gmail Integration":

"If you connect your Gmail account, TZI-CRM accesses your email messages solely to display them within the CRM's Email Chat feature and does not use this data for advertising or share it with third parties. Our use and transfer of information received from Google APIs adheres to the [Google API Services User Data Policy](#), including the Limited Use requirements."

4. Employee/team location tracking — missing, and this is sensitive personal data

Evidence: `SAAS_CRM_BACKEND/controllers/location.controller.js`, `docs/device-location-api.md` — client (browser/mobile) reports GPS coordinates every ~30s while the "Live Team Locations" feature is active; visible to Admins in real time via Socket.IO. **No consent flow was found in the codebase either** — this is a product gap as well as a documentation gap.

Required addition — "Location Data":

"If your organization enables Live Team Locations, the Service collects your device's GPS coordinates while you are logged in, for the purpose of allowing your organization's Admin to view team locations in real time. This data is visible only to Admins within your tenant and is not shared outside your organization. [Describe retention period.] Employers are responsible for notifying and obtaining any consent required from their employees under applicable labor and privacy law before enabling this feature."

Recommend separately (product, not just docs): add an explicit in-app consent/notice screen before location tracking starts, since this is a real gap, not just a documentation one.

5. Device/session data — missing

Evidence: `models/schemas/deviceSessionSchema.js` — stores device type, client-generated device ID, human-readable label, IP address, per login session, with an admin-approval flow for new devices ("Device Login Requests").

Required addition: brief section noting device identifiers, IP address, and session metadata are collected for account security (to detect/approve new device logins).

6. Payment/financial information — overstated and inaccurate

Lines 124-141 describe collecting "a credit card and debit card number" directly on a "customer order form." Since **no payment gateway is integrated** and billing is manual/invoiced (see companion Terms & Conditions review), this section describes something that doesn't happen and could create false expectations (or liability if it did happen without PCI-DSS compliance). Either:

- Remove the credit/debit card language entirely (billing is manual, invoice-based), or
 - If online payments are added later, name the actual processor and state that TZI-CRM does not store full card numbers (tokenized by the processor).
-

7. India's DPDP Act 2023 — not referenced

Once the Terms' governing-law placeholder is fixed, governing law is India, and the Service processes personal data of Indian data principals (leads, contacts). Add a short section referencing compliance with the **Digital Personal Data Protection Act, 2023**, including data principal rights (access, correction, erasure, grievance redressal) and the identity/contact of a grievance officer if required at your data volume.

8. Data retention — not specified anywhere

The policy doesn't state how long Customer Data, messages, location data, or account data is kept after account/tenant cancellation. Add explicit retention periods (ties to the cancellation clause in the Terms).

9. Sub-processors not listed

The policy should list (or link to) the third parties that process personal data on TZI-CRM's behalf: Meta (WhatsApp/Instagram/Facebook Graph API), Google (Gmail API), Gmail SMTP for transactional email, and the hosting provider. Currently none are named.

10. Multi-tenant data isolation — worth stating (trust/marketing value)

`SAAS_CRM_BACKEND/config/tenantDB.js` shows one physical MongoDB database per tenant (not row-level filtering). This is a strong data-isolation guarantee worth stating explicitly in the Privacy Policy or a Security page — customers evaluating a CRM often ask exactly this question.

11. Consistency / factual errors to fix regardless of the rewrite

12. Priority order

Issue	Location	Fix
Support email mismatch	Privacy Policy uses <code>service@techzarinfo.com</code> (line 55); <code>Footer.tsx</code> / <code>ContactInfo.tsx</code> use <code>sales@techzarinfo.com</code>	Pick one support address (recommend a distinct <code>support@techzarinfo.com</code> , separate from <code>sales@</code>) and use it consistently
No physical address in the document	Only in <code>Footer.tsx</code> : "No.3D, M.S Tower, 4th Floor, Convent Rd, Cantonment, Tiruchirappalli - 620001"	Add company legal address (typically required for DPDP grievance officer contact)

-
1. Add the Meta Platform Data + Data Deletion Instructions section (§2) — needed for continued Meta API access, not just optics.
2. Add the Google/Gmail Limited Use disclosure (§3) — same reasoning for Google API access.
3. Add the Location Data section (§4) — sensitive personal data currently undisclosed.
4. Fix the payment/financial information section to match reality (§6).
5. Fix the support-email inconsistency (§11).
6. Everything else (§1, §5, §7-§10) — important for compliance completeness but lower urgency than 1-5.